Referência da API

Documentação técnica - Manual Operacional Digital

Base local: `http://localhost:4000`. Arquitetura do backend: ../README.md. Especificação importável: openapi.yaml.

Convenções

- Rotas protegidas exigem `Authorization: Bearer <token>`.
- Corpo JSON com `Content-Type: application/json`. Upload de manual usa `multipart/form-data` (não defina o boundary manualmente).
- IDs de rota são inteiros. Datas são strings ISO 8601.
- Exclusão bem-sucedida retorna `204` sem corpo.
- Erros retornam `{ "message": "descrição" }`.

Perfis

Código	Significado	Nesta documentação
`usuario`	Operador	Autenticado
`gerente_setor`	Gerente restrito aos próprios setores (um ou mais)	Gerência
`suporte`	Administração global	Suporte, Gerência
`gerente`	Legado; ainda aceito pelos middlewares, mas o banco não permite gravá-lo	—

Gerência = `gerente_setor` ou `suporte`. **Suporte** = só `suporte`.

Endpoints

Método e rota	Acesso	Documento
`GET /health`	Público	HEALTH.md
`POST /api/auth/login`	Público	AUTH.md
`GET /api/auth/me`	Autenticado	AUTH.md
`PUT /api/auth/password`	Autenticado	AUTH.md
`POST /api/auth/register`	Suporte	AUTH.md
`GET /api/users`	Suporte	USERS.md
`PUT /api/users/{id}`	Suporte	USERS.md
`DELETE /api/users/{id}`	Suporte	USERS.md
`GET /api/sectors`	Gerência	SECTORS.md
`POST /api/sectors`	Suporte	SECTORS.md
`GET /api/systems`	Autenticado	SYSTEMS.md
`POST /api/systems`	Suporte	SYSTEMS.md
`PUT /api/systems/{id}`	Suporte	SYSTEMS.md
`DELETE /api/systems/{id}`	Suporte	SYSTEMS.md
`GET /api/manuals`	Autenticado	MANUALS.md
`GET /api/manuals/{id}`	Autenticado com visibilidade	MANUALS.md
`POST /api/manuals`	Gerência	MANUALS.md
`PUT /api/manuals/{id}`	Suporte	MANUALS.md
`DELETE /api/manuals/{id}`	Suporte	MANUALS.md
`GET /api/uploads/config`	Gerência	UPLOADS.md
`POST /api/uploads/presign`	Gerência	UPLOADS.md
`GET /uploads/{pasta}/{arquivo}`	Público	MANUALS.md
`GET /api/progress/report`	Gerência	PROGRESS.md
`GET /api/progress/{manualId}`	Autenticado com visibilidade	PROGRESS.md
`PUT /api/progress/{manualId}`	Autenticado com visibilidade	PROGRESS.md
`POST /api/exams`	Gerência	EXAMS.md
`GET /api/exams/available`	Autenticado	EXAMS.md
`GET /api/exams/results`	Gerência	EXAMS.md
`GET /api/exams/{id}`	Colaborador do setor da prova	EXAMS.md
`POST /api/exams/{id}/submissions`	Colaborador do setor da prova	EXAMS.md

Códigos de resposta

Código	Uso
`200`	Consulta ou atualização concluída
`201`	Recurso criado
`204`	Sucesso sem corpo
`400`	Dados inválidos ou regra de negócio
`401`	Token ausente, inválido ou expirado; credenciais inválidas
`403`	Perfil sem permissão
`404`	Recurso inexistente, sem visibilidade ou rota desconhecida
`409`	Exclusão de sistema com manuais vinculados
`429`	Login bloqueado por excesso de tentativas
`500`	Erro interno, banco indisponível ou identificador duplicado

API de saúde

Documentação técnica - Manual Operacional Digital

`GET /health`

Acesso: público.

Confirma que o processo HTTP está respondendo. Não consulta PostgreSQL nem armazenamento.

Resposta `200`:

```
{ "status": "ok", "service": "Manual Operacional Digital API" }
```

Use no health check de **vida** (reiniciar o processo se não responder).

`GET /health/ready`

Acesso: público.

Executa `SELECT 1` no PostgreSQL. Use no health check de **prontidão** (decidir se a instância recebe tráfego).

Resposta `200`:

```
{ "status": "ok", "database": "ok" }
```

Resposta `503` quando o banco não responde:

```
{ "status": "unavailable", "database": "indisponivel" }
```

API de autenticação e sessão

Documentação técnica - Manual Operacional Digital

Base: `/api/auth`.

POST /login

Acesso: público.

```
{ "identificador": "admin", "senha": "admin123" }
```

Fluxo: valida os campos; verifica bloqueio para a combinação IP + identificador; busca o usuário por `identificador` (ou pelo `email` legado); compara o hash bcrypt. Cada falha conta uma tentativa; na quinta, o login fica bloqueado por 15 minutos. Em caso de sucesso, zera as falhas, grava auditoria `login` e emite o JWT.

Resposta `200`:

```
{
  "token": "eyJ...",
  "user": { "id": 1, "nome": "Suporte Admin", "identificador": "admin", "role": "suporte", "sector_ids":
[], "setores": [] }
}
```

O JWT expira em 8 horas e contém `id`, `nome` e `role`. Os setores não ficam no token: são lidos do banco a cada requisição, então mudar os setores de um usuário vale na hora.

Erros: `400` campos ausentes · `401` credenciais inválidas · `429` bloqueado · `500` sem `JWT_SECRET` configurado.

GET /me

Acesso: autenticado.

Retorna `id`, `nome`, `identificador`, `email`, `role`, `sector_ids` (lista de ids), `setores` (lista de `{ id, nome }`, em ordem alfabética) e `created_at` do usuário do token. O frontend usa esta rota ao recarregar a página.

PUT /password

Acesso: autenticado. Troca a própria senha.

```
{ "currentPassword": "admin123", "newPassword": "NovaSenha2026" }
```

Fluxo: exige nova senha com 8+ caracteres, uma letra e um número; confere a senha atual; grava o novo hash; registra auditoria `password_changed`.

Respostas: `204` sucesso · `400` senha atual incorreta ou nova senha fraca.

POST /register

Acesso: suporte. Cria usuário.

```
{
  "nome": "Maria Silva",
  "identificador": "maria.silva",
  "senha": "Treino2026",
  "role": "usuario",
  "sectorIds": [3, 5]
```

```
}
```

- `role`: `suporte`, `gerente_setor` ou `usuario` (padrão `usuario`).
- `sectorIds`: ids dos setores (um ou mais). Obrigatório para `usuario` e `gerente_setor`; opcional para `suporte`. Os setores precisam existir (são criados em `POST /api/sectors`).
- Senha segue a mesma política da troca de senha.

Respostas: `201` com o usuário sem senha · `400` campos ausentes, perfil inválido ou senha fraca · `403` sem permissão · `500` identificador já existente.

API de usuários

Documentação técnica - Manual Operacional Digital

Base: `/api/users`. **Acesso:** suporte em todas as rotas. Para criar usuário, ver AUTH.md.

GET /

Lista usuários em ordem alfabética: `id`, `nome`, `identificador`, `email`, `role`, `sector_ids`, `setores` (`{ id, nome }`), `created_at`. A senha nunca é retornada.

PUT /{id}

Atualiza dados administrativos e substitui a lista de setores. `nome`, `identificador` e `role` são obrigatórios; `sectorIds` é obrigatório (com pelo menos um setor) para operador e gerente de setor. Não altera a senha.

```
{ "nome": "Maria Silva", "identificador": "maria.silva", "role": "gerente_setor", "sectorIds": [3, 5] }
```

Respostas: `200` usuário atualizado · `400` campos ou perfil inválidos, nenhum setor ou setor inexistente · `404` usuário inexistente.

A mudança de setores vale na hora. A mudança de perfil só vale a partir do próximo login (o perfil fica no token).

DELETE /{id}

Respostas: `204` excluído · `400` tentativa de excluir a própria conta.

Atenção: a exclusão apaga em cascata o progresso, as entregas de provas e o histórico de progresso do usuário. Manuais criados por ele e registros de auditoria ficam com o autor nulo.

Limitações

- Não há rota para o suporte redefinir a senha de outro usuário.
- Não há inativação de usuário; a única opção é excluir.

API de setores

Documentação técnica - Manual Operacional Digital

Base: `/api/sectors`.

GET /

Acesso: gerência. Retorna `[{ "id": 1, "nome": "Geral" }]` em ordem alfabética.

POST /

Acesso: suporte.

```
{ "nome": "Recepção" }
```

Remove espaços nas pontas. Se o nome já existir, devolve o setor existente; senão, cria. **Respostas:** `201` · `400` nome vazio.

Setores também são criados automaticamente quando um nome novo é informado no cadastro de usuário ou de manual.

Limitações

Não há rotas para renomear ou excluir setor.

API de sistemas

Documentação técnica - Manual Operacional Digital

Base: `/api/systems`.

GET /

Acesso: autenticado. Lista todos os sistemas em ordem alfabética. `manuals_count` conta só os manuais visíveis ao usuário (suporte: todos; demais: ativos dos seus setores).

POST /

Acesso: suporte.

```
{ "nome": "Aliança PX", "resumo": "Procedimentos da operadora" }
```

`nome` obrigatório. **Respostas:** `201` · `400` sem nome.

PUT /{id}

Acesso: suporte. Aceita `nome` e/ou `resumo`; campos ausentes são mantidos. **Respostas:** `200` · `404`.

DELETE /{id}

Acesso: suporte.

Respostas: `204` excluído · `409` existe manual vinculado ao sistema (a exclusão é bloqueada; os manuais **não** ficam sem sistema).

API de manuais e arquivos

Documentação técnica - Manual Operacional Digital

Base: `/api/manuals`.

GET /

Acesso: autenticado. Filtro opcional `?systemId=3`.

- Suporte: todos os manuais (ativos e inativos).
- Operador e gerente de setor: somente manuais ativos dos setores do usuário (pode ter mais de um).

Cada item traz os dados do manual, `criado_por_nome` e, do usuário logado, `first_access_at`, `completed_at` e `progress_percent` (páginas do PDF valem até 50%, vídeo até 50%). Ordem: mais recentes primeiro.

GET /{id}

Acesso: autenticado. Suporte abre qualquer manual; os demais só manuais ativos dos seus setores. Sem acesso, responde `404` (não revela que o manual existe).

No modo `s3`, `pdf_url` e `video_url` voltam como **URLs assinadas temporárias** (validade `FILE_URL_TTL_SECONDS`, padrão 4 horas), geradas só depois de conferir o acesso. Na listagem (`GET /`) esses campos trazem a chave do objeto, que não abre o arquivo sozinha.

POST /

Acesso: gerência. Dois formatos:

- `multipart/form-data` com os arquivos nos campos `pdf` e `video` (modos `local` e `supabase`, ou arquivos pequenos);
- JSON com `pdfKey` e `videoKey` no lugar dos arquivos, depois do upload direto ao bucket (UPLOADS.md). É o formato usado pela tela no modo `s3`, e o único que aceita vídeos grandes no Cloud Run.

Campo	Tipo	Obrigatório	Observação
`titulo`	texto	Sim	Até 180 caracteres
`descricao`	texto	Não	
`systemId`	inteiro	Sim	Sistema existente
`setor`	texto	Sim para suporte	Gerente de setor só publica em um dos seus setores: com um setor, pode omitir; com vários, deve informar qual. Outro setor responde `400`
`pdf`	arquivo	Sim	`application/pdf`
`video`	arquivo	Sim	MP4, WebM ou QuickTime

Limites: PDF até 20 MB e vídeo até 200 MB (variáveis `UPLOAD_MAX_PDF_MB` e `UPLOAD_MAX_VIDEO_MB`). A tela também recusa vídeo com mais de 10 minutos; a API não confere a duração. Para o suporte, setor inexistente é criado.

```
curl -X POST http://localhost:4000/api/manuals \
  -H "Authorization: Bearer TOKEN" \
  -F "titulo=Cadastro de paciente" -F "systemId=1" -F "setor=Recepção" \
  -F "pdf=@manual.pdf;type=application/pdf" \
  -F "video=@treinamento.mp4;type=video/mp4"
```

Fluxo: grava os arquivos (PDF com neutralização de impressão automática), cria/reutiliza o setor, insere o manual.

Respostas: `201` manual criado · `400` campo obrigatório ausente, tipo não permitido ou chave inválida/inexistente · `413` arquivo acima do limite.

O manual não tem questionário nem prazo. A avaliação é feita pelas provas (EXAMS.md).

`PUT /{id}`

Acesso: suporte. Formato `multipart/form-data` ou JSON; todos os campos são opcionais: `titulo`, `descricao`, `systemId`, `setor`, `active` (`"true"` ou `"false"`), `pdf`/`pdfKey`, `video`/`videoKey`.

- Enviar `pdf` ou `video` gera nova versão: arquiva a versão e o progresso atuais, apaga o progresso ativo e incrementa `version` (regras em REGRAS-DE-NEGOCIO.md).

Respostas: `200` · `404`.

`DELETE /{id}`

Acesso: suporte. **Resposta:** `204`.

Remove em cascata progresso, perguntas, tentativas, permissões e históricos do manual. Os arquivos no armazenamento **não** são apagados.

Arquivos

`GET /uploads/{pasta}/{arquivo}`

Acesso: público. Usado só no modo `local` (desenvolvimento): serve os arquivos de `backend/uploads` (`pdfs/` e `videos/`). No modo `supabase`, o banco guarda a URL pública do bucket. Nesses dois modos, quem tiver o link abre o arquivo sem login.

No modo `s3` o bucket é privado: o banco guarda a chave do objeto e o arquivo só abre pela URL assinada devolvida em `GET /{id}`.

API de upload direto

Documentação técnica - Manual Operacional Digital

Base: `/api/uploads`. Usada quando o backend está no modo `s3` (bucket compatível com S3, como o Cloudflare R2 do piloto). O navegador envia o PDF e o vídeo direto ao bucket por uma URL assinada; o backend só autoriza, assina e depois confere o arquivo ao salvar o manual.

`GET /config`

Acesso: gerência (suporte ou gerente de setor).

Resposta `200`:

```
{ "directUpload": true, "driver": "s3", "limits": { "pdfMb": 20, "videoMb": 200 } }
```

`directUpload: false` (modos `local` ou `supabase`): a tela envia os arquivos no próprio `POST /api/manuals` em `multipart/form-data`.

`POST /presign`

Acesso: gerência. Corpo JSON:

Campo	Tipo	Observação
`kind`	`pdf` ou `video`	
`contentType`	texto	PDF: `application/pdf`. Vídeo: `video/mp4`, `video/webm` ou `video/quicktime`
`size`	inteiro	Tamanho em bytes; acima do limite responde `413`

Resposta `200`:

```
{
  "key": "videos/2f6c...e1.mp4",
  "method": "PUT",
  "url": "https://<conta>.r2.cloudflarestorage.com/<bucket>/videos/2f6c...e1.mp4?X-Amz-...",
  "headers": { "Content-Type": "video/mp4" },
  "expiresIn": 600
}
```

O navegador faz `PUT` do arquivo em `url` com os `headers` informados. Depois envia `key` como `pdfKey` ou `videoKey` no cadastro do manual (MANUALS.md).

Respostas: `200` · `400` tipo não permitido ou upload direto não configurado · `403` perfil sem permissão · `413` acima do limite.

Conferência ao salvar o manual

Ao receber `pdfKey`/`videoKey`, o backend confere no bucket:

- a chave segue o padrão `pdfs/<uuid>.pdf` ou `videos/<uuid>.<ext>` e está na pasta do campo certo;
- o objeto existe;
- o tamanho real está dentro do limite (se passar, o objeto é apagado e a resposta é `413`);

- o tipo é permitido;
- o PDF começa com `%PDF-` e tem a impressão automática neutralizada.

Não existe limite de duração do vídeo no servidor; a tela recusa vídeos acima de 10 minutos.

API de progresso e painel

Documentação técnica - Manual Operacional Digital

Base: `/api/progress`.

GET /{manualId}

Acesso: autenticado com visibilidade do manual. Retorna o progresso do próprio usuário. Sem registro ainda, devolve valores iniciais.

```
{
  "user_id": 5, "manual_id": 9,
  "pdf_completed": false, "video_progress": "34.50",
  "total_seconds": 180, "page_count": 10, "last_page": 4,
  "pages_viewed": [1, 2, 3, 4],
  "first_access_at": "2026-10-16T12:00:00.000Z",
  "last_access_at": "2026-10-16T12:10:00.000Z",
  "completed_at": null
}
```

`video_progress` vem como texto (tipo NUMERIC do PostgreSQL).

PUT /{manualId}

Acesso: autenticado com visibilidade do manual. Atualização incremental; todos os campos são opcionais.

```
{ "page": 4, "pageCount": 10, "videoProgress": 34.5, "seconds": 30, "pdfCompleted": false }
```

Regras aplicadas pelo servidor:

- cria o registro no primeiro envio;
- páginas são somadas ao conjunto já visto, sem repetir;
- `page_count` e `last_page` guardam o maior valor recebido;
- `videoProgress` limitado a 0–100 e nunca diminui;
- `seconds` limitado a 60 por chamada e acumulado;
- PDF concluído quando todas as páginas foram vistas **ou** quando `pdfCompleted: true` é enviado;
- manual concluído quando PDF concluído e vídeo >= 90%.

Resposta: o progresso consolidado (mesmo formato do `GET`).

Problema conhecido: como `pdfCompleted` e `videoProgress` são aceitos sem conferência, uma chamada direta marca o manual como lido e assistido.

GET /report

Acesso: gerência. Gerente de setor recebe só os próprios setores; suporte recebe todos.

Uma linha por combinação operador (perfil `usuario`) x manual de cada setor dele, inclusive não iniciados. `sector_name` é o setor do manual; um operador com vários setores aparece uma vez por manual. Inclui manuais inativos.

Campos: `user_id`, `user_name`, `sector_name`, `manual_id`, `manual_title`, `pdf_completed`, `video_progress`, `first_access_at`, `last_access_at`, `completed_at`, `total_seconds`, `page_count`,

`pages_read`, `version`.

É a fonte do Painel de uso e da exportação CSV feita no navegador.

API de provas

Documentação técnica - Manual Operacional Digital

Base: `/api/exams`. Regras de negócio em REGRAS-DE-NEGOCIO.md. Tabelas em Banco de Dados.

Gerente de setor cria provas para um dos seus setores. Suporte escolhe um setor ou todos os setores. Quem responde são os colaboradores (perfil `usuario`) do setor da prova, ou de todos os setores.

POST /

Acesso: gerência (gerente de setor ou suporte). Formato JSON. Gerente de setor escolhe um dos seus setores em `sectorId`; se tiver só um, pode omitir.

Campo	Tipo	Obrigatório	Observação
`sectorId`	número ou `"todos"`	Depende	Suporte: id do setor, ou `"todos"` (ou vazio) para todos os setores. Gerente de setor: id de um dos seus setores, obrigatório se tiver mais de um
`titulo`	texto	Sim	Até 180 caracteres
`descricao`	texto	Não	
`startsAt`	data e hora ISO 8601	Sim	Início do período de realização
`endsAt`	data e hora ISO 8601	Sim	Final do período; deve ser depois do início
`questions`	lista	Sim	De 1 a 10 perguntas, na ordem em que serão exibidas

Cada pergunta:

Campo	Múltipla escolha	Resposta aberta
`type`	`"multipla_escolha"`	`"aberta"`
`prompt`	enunciado	enunciado
`options`	4 textos, na ordem A, B, C, D	não enviar
`correctOption`	índice da correta: 0 (A) a 3 (D)	não enviar

```
{
  "titulo": "Prova de Faturamento - Outubro",
  "startsAt": "2026-10-20T11:00:00.000Z",
  "endsAt": "2026-10-21T21:00:00.000Z",
  "questions": [
    { "type": "multipla_escolha", "prompt": "Qual guia é usada para internação?", "options": ["SP/SADT",
"Internação", "Consulta", "Honorários"], "correctOption": 1 },
    { "type": "aberta", "prompt": "Descreva como conferir uma guia antes do envio." }
  ]
}
```

Respostas: `201` prova criada (com `question_count`) · `400` validação (mensagem indica o campo ou a pergunta) setor não encontrado, gerente sem setor ou fora dos seus setores · `403` perfil sem permissão.

GET /available

Acesso: autenticado. Para colaboradores, lista as provas dos seus setores e as de todos os setores que estão no período, ativas e ainda não entregues por ele, da que termina primeiro para a última. Para os demais perfis devolve `[]`.

```
[{ "id": 1, "titulo": "Prova de Faturamento - Outubro", "descricao": null, "starts_at": "...", "ends_at":
 "...", "question_count": 2 }]
```

É a fonte do pop-up de prova disponível e da tela **Provas**.

GET /{id}

Acesso: colaborador de um dos setores da prova (ou qualquer colaborador, se for para todos os setores). Devolve a prova e as perguntas **sem** a alternativa correta.

```
{ "id": 1, "titulo": "...", "descricao": null, "starts_at": "...", "ends_at": "...",
  "questions": [{ "id": 7, "position": 0, "type": "multipla_escolha", "prompt": "...", "options": ["...",
 "...", "...", "..."] }] }
```

Respostas: `404` prova inexistente, de outro setor ou perfil diferente de colaborador · `409` fora do período ou já entregue.

POST /{id}/submissions

Acesso: colaborador do setor da prova. As chaves de `answers` são os IDs das perguntas. Múltipla escolha recebe o índice da alternativa (0 a 3); resposta aberta recebe o texto.

```
{ "answers": { "7": 1, "8": "Confiro carteirinha, CID e assinatura." } }
```

Resposta `201`:

```
{ "objectiveTotal": 1, "objectiveCorrect": 1 }
```

- Todas as perguntas precisam de resposta; faltando alguma, responde `400` indicando qual.
- Uma entrega por colaborador; a segunda tentativa responde `409`.
- A nota considera só as perguntas de múltipla escolha.

GET /results

Acesso: gerência. Suporte recebe todas. Gerente de setor recebe as dos seus setores e as de todos os setores; `collaborators` e `submissions` contam só colaboradores que pertencem a um dos setores dele. Ordenadas da mais recente para a mais antiga.

Cada prova traz `sector_name` ("Todos os setores" quando `sector_id` é nulo), `criado_por_nome`, `collaborators` (colaboradores do setor), `questions` (com `correct_option`) e `submissions`. Cada entrega traz `user_name`, `objective_total`, `objective_correct`, `submitted_at` e `answers` (`question_id`, `selected_option`, `answer_text`).

É a fonte da aba **Resultados de Provas** do Painel de uso.